

Cyfrin
Security Review: Sample DEX

[C-1] Missing access control on admin setter

Description

The setFeeRecipient function in contracts/DEX.sol:88 has no onlyOwner guard. Any caller can redirect the protocol fee stream.

Impact

Complete protocol fee revenue stream is redirected to attacker.

Recommendation

Add an onlyOwner modifier to setFeeRecipient.

[H-1] Integer overflow in fee calculation

Description

The fee calc in contracts/DEX.sol:200 multiplies unchecked uints.

Impact

Large inputs trigger overflow leading to incorrect fee accounting.

Recommendation

Use Solidity 0.8+ checked arithmetic.

[M-1] Incorrect event emission order

Description

Events in contracts/DEX.sol:300 emit before state is updated.

Impact

Off-chain indexers may capture an inconsistent state snapshot.

Recommendation

Move the emit to after the state update.

[L-1] Missing zero-address check on token setter

Description

The setToken function in contracts/DEX.sol:400 lacks a zero check.

Impact

Misconfiguration could brick the contract.

Recommendation

Add require(newToken != address(0)) guard.

[I-1] Inconsistent comment style across modules

Description

Comments in contracts/DEX.sol mix NatSpec and inline conventions.

Impact

Documentation generation tools may produce incomplete output.

Recommendation

Standardise on NatSpec for all public/external functions.

[G-1] Cache storage reads in claim loop

Description

The claim loop in contracts/DEX.sol:500 re-reads storage per iter.

Recommendation

Cache the storage variable in a memory local before the loop.